



Information Security Policy & Controls

Prepared By :

Jagadeesh Duggirala
Infosec Engineer

Reviewed By :

Shashank Srivastava
(CoFounder & CTO)

Approved By :

Richard Samuel
(Founder & CEO)

Version : 1.0**19 Mar, 2026**

1.Introduction

This document defines the information security architecture, controls, and operational practices implemented by DexKorCRM Private Limited ("DexKor").

DexKor ensures:

- Confidentiality of customer and tenant data
- Integrity of authentication and application workflows
- High availability and resilience of services

The system is designed with redundancy and monitoring to ensure high availability.

This document reflects actual implementation across backend systems including the chat-server and auth-microservice.

All controls described in this document are actively enforced in production environments. We rely on industry-leading cloud providers with globally recognized security certifications.

2. Scope

This policy applies to:

- Backend services (chat-server, auth-microservice)
- Cloud infrastructure (AWS)
- Authentication and identity systems
- Databases and storage systems
- Multi-tenant architecture



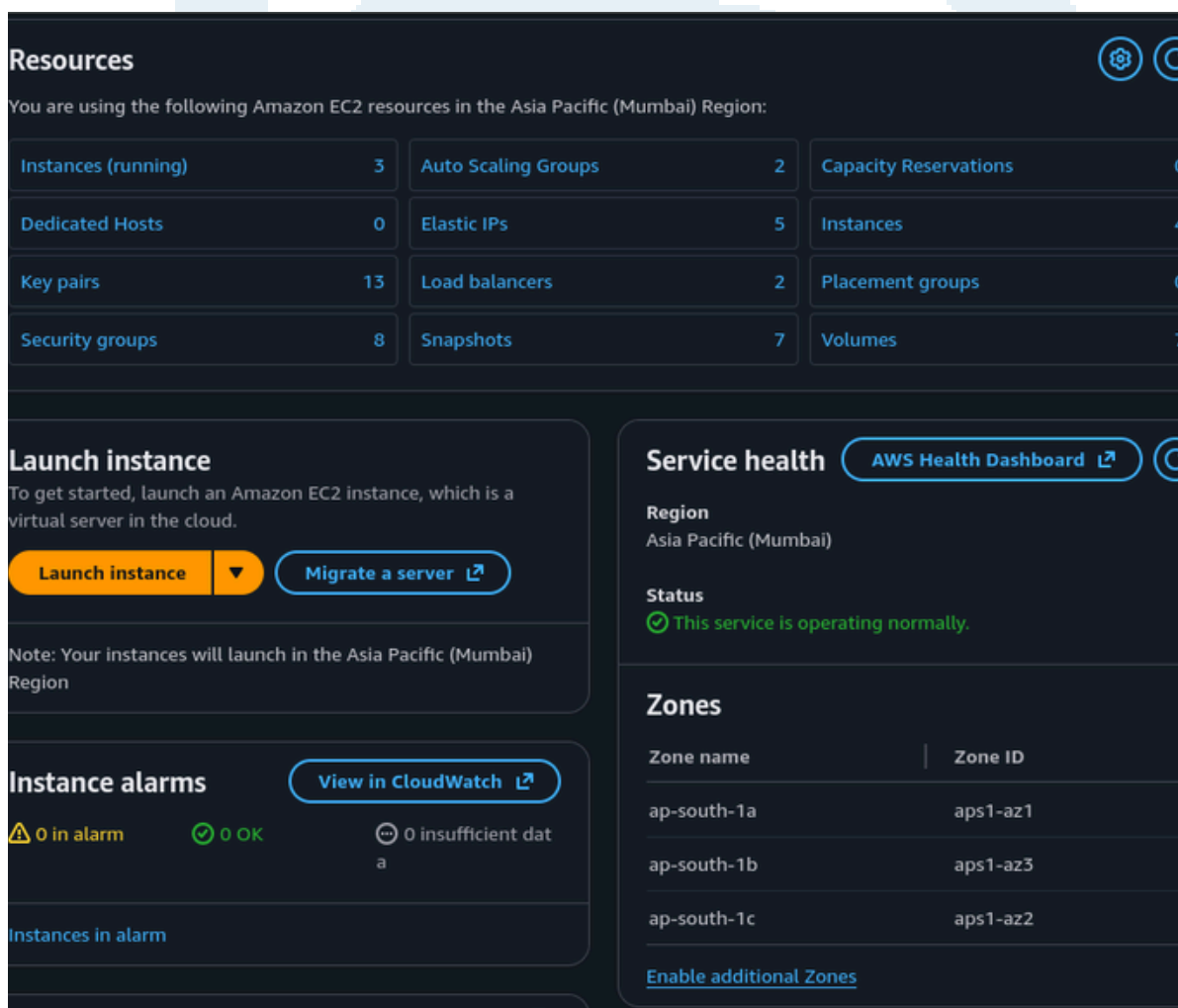
3. Infrastructure Security

3.1 Cloud Hosting

DexKor is deployed on Amazon Web Services (AWS) using managed infrastructure and deployment pipelines.

Controls:

- Region-specific hosting (e.g., ap-south-1)
- IAM-based access control
- Network isolation via VPC



AWS Infrastructure Overview (ap-south-1 Mumbai Region)

Roles (122) Info

An IAM role is an identity you can create that has specific permissions with credentials that are valid for short durations. Roles can be assumed by entities that you trust.

Search

Role name	Trusted entities
admin-poratl	AWS Service: elasticbeanstalk
AIOpsRole-DefaultInvestigationGroup-oj5yii	AWS Service: alogs
Amazon_EventBridge_Scheduler_LAMBDA_c3db5973de	AWS Service: scheduler
Amazon_EventBridge_Scheduler_LAMBDA_e4b15603c7	AWS Service: scheduler
AmazonBedrockExecutionRoleForAgents_ORW3KS0Fi2C	AWS Service: bedrock
AmazonKendra-ap-south-1-kendra-test-1-dexy	AWS Service: kendra
AmazonKendra-sample-s3-role-bb9a6a8c-dc30-4e6a-95e3-759226b33529	AWS Service: kendra
AmplifySSRLLoggingRole-23182c07-e69f-4ea3-8c19-7b706337b619	AWS Service: amplify
AmplifySSRLLoggingRole-51674b1e-e749-4a03-b828-ec373fad16ad	AWS Service: amplify
AmplifySSRLLoggingRole-c30ac1d2-2c02-4c6d-9e59-165a9d2454ef	AWS Service: amplify
AmplifySSRLLoggingRole-f1528fb3-26e2-46bb-91c2-a9d00158561f	AWS Service: amplify
ATMOSLY-B38fc84a-5df5-49fc-8030-a4774278638c	Account: 114157090608, and 3 more
ATMOSLY-B38fc84a-5df5-49fc-8030-a4774278638c-NodegroupRole	AWS Service: ec2
aws-elasticbeanstalk-service-role	AWS Service: elasticbeanstalk
aws-elasticbeanstalk-service-role-auth-microservice	AWS Service: elasticbeanstalk
aws-elasticbeanstalk-service-role-authentication-prod	AWS Service: elasticbeanstalk

AWS IAM Roles and Access Configuration

Your VPCs

VPCs | VPC encryption controls

Your VPCs (2) Info

Find VPCs by attribute or tag

Last updated less than a minute ago

Actions Create VPC

Name	VPC ID	State	Encryption c...	Encryption control ...	Block Public...	IPv4 CIDR
-	vpc-0cf424e2f4ee2568e	Available	-	-	Off	172.31.0.0/16
production-vpc	vpc-082b7a592a714f5c4	Available	-	-	Off	10.0.0.0/16

AWS VPC Configuration and Network Isolation



3.2 Multi-Tenant Logical Isolation

Controls:

- Tenant isolation enforced via uniquePartnerId
- All queries scoped to tenant context
- Prevention of cross-tenant data leakage

LEAD		
PK	uniquePartnerId	Objectid
UQ, NULL	leadCode	String
NOT_NULL	isConverted	Boolean
NULL	convertedAccountId	Objectid
NULL	convertedContactId	Objectid
NULL	convertedDealId	Objectid
NULL	convertedBy	Objectid
NULL	createdBy	Objectid
NULL	updatedBy	Objectid
UQ, NULL	chatbotSessionId	String
NOT_NULL	dupicacy	Boolean
NULL	relatedLeadIds	Array
NULL	lastDuplicateCheckedAt	Date

Tenant Identifier to enforce isolation

Database Schema Representation (Application Data Model)

4. Data Security Controls

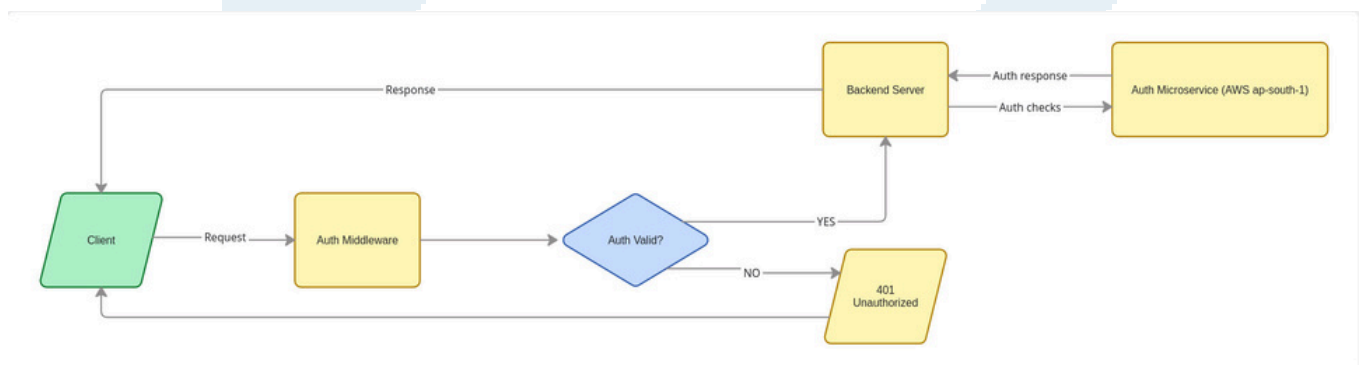
4.1 Encryption

Controls:

- Encryption at rest is enforced via managed MongoDB Atlas (AES-256 enabled by default).
- Encryption keys are managed via cloud provider-managed key management systems (MongoDB Atlas managed keys).
- TLS 1.2+ encryption in transit
- Enforced HTTPS requirement

VERSION	REGION	CLUSTER TIER	ENCRYPTED STORAGE
8.0.20	AWS Mumbai (ap-south-1)	M20 (General)	True

MongoDB Database Configuration



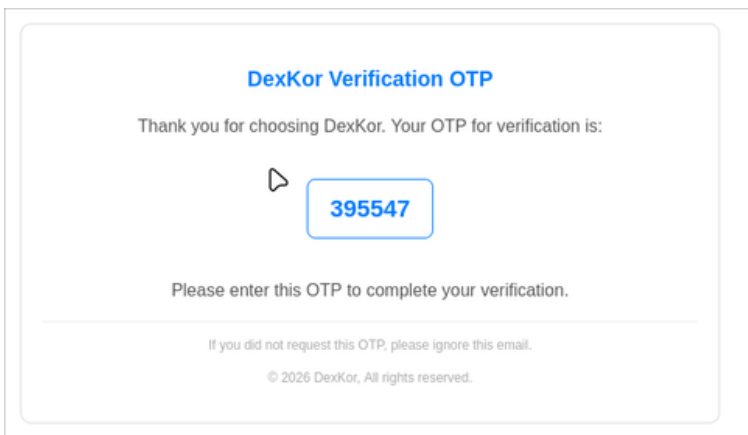
Authentication Middleware and Token Validation Flow

4.2 Credential Security

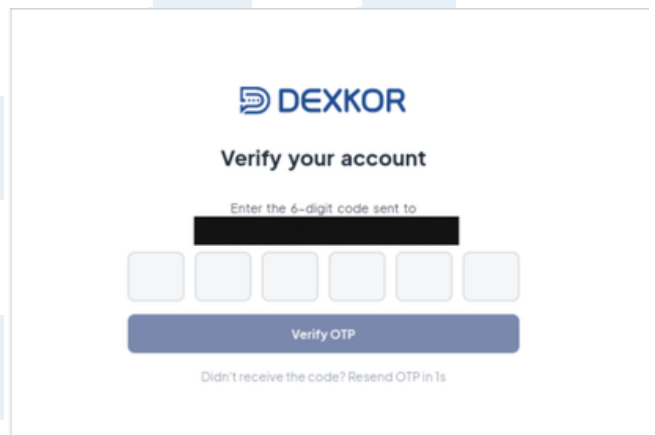
Controls:

- Enforced OTP Login
- Protection against brute-force and rainbow table attacks
- OTP is valid for only 10 minutes.
- OTP Delivery via Email
- OTP generated using cryptographically secure random number generation.
- *OTP resend and retry attempts are limited to a maximum of 5 within a 10-minute window; exceeding this threshold will block further attempts for 60 minutes, after which the user must wait or contact DexKor for assistance.*

Evidence:



OTP Delivery via Email



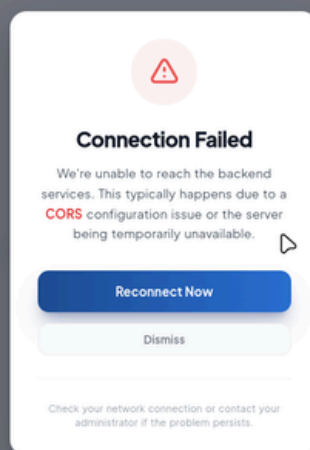
OTP Verification Interface

4.3 API Communication Security

Controls:

- Dynamic CORS validation
- Restricted origin access
- Authentication required for all APIs

Evidence:



CORS Failure Screen



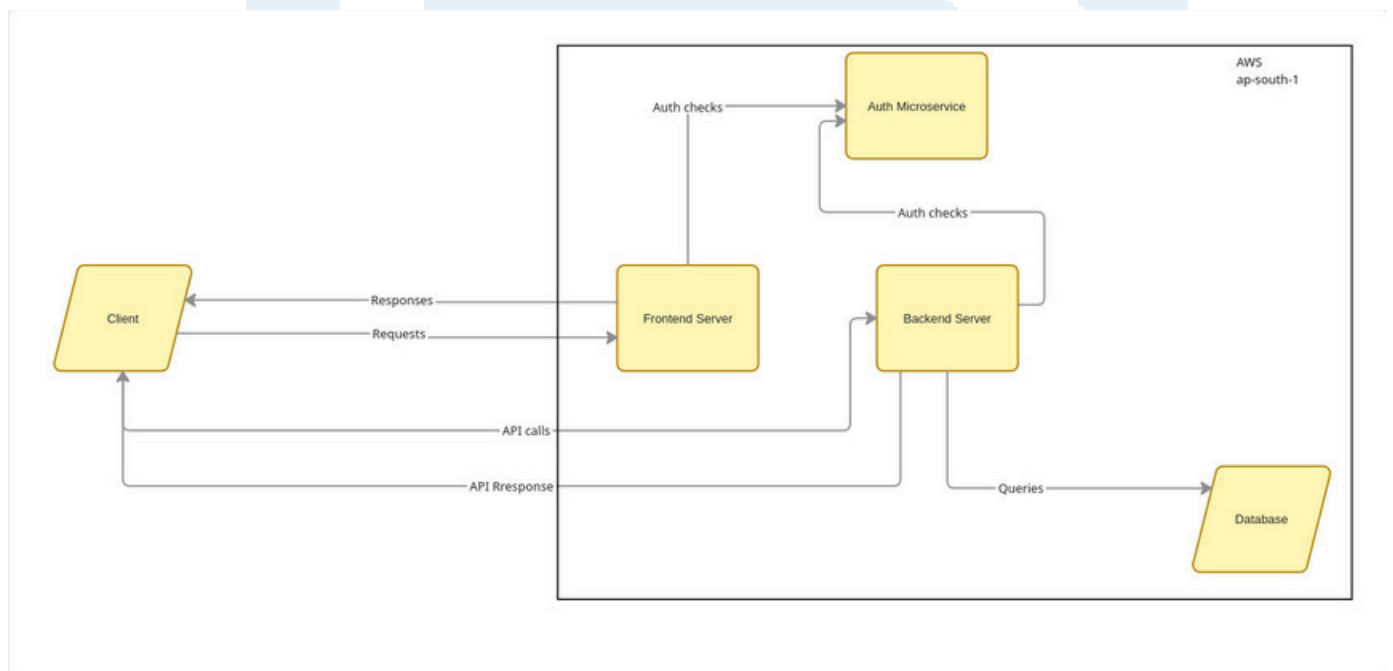
5. Access Control & Identity Management

5.1 Centralized Identity Architecture

DexKor uses a dedicated Auth Microservice as the single source of truth for authentication and identity.

Controls:

- All services delegate authentication to auth-microservice
- Centralized token issuance and validation
- Decoupled identity and application layers



DexKor System Architecture

5.2 Role-Based Access Control (RBAC)

Controls:

- Fine-grained permission system
- Role, team, and tenant-based access control
- Wildcard permissions supported
- Least privilege enforced
- Access permissions are reviewed periodically (e.g., quarterly or upon role change).

Evidence:

Role Name	Description	Type	Permissions	Actions
Admins	admin	CUSTOM	77 permissions	⋮
Full Access NPS	Account Care: - NPS: Full Ac	CUSTOM	4 permissions	⋮
NPS Export	NPS Export	CUSTOM	3 permissions	⋮
Opportunity	Opportunity Full view	CUSTOM	1 permissions	⋮
Opportunity - View Only	Account Care: - Opportunity:	CUSTOM	1 permissions	⋮
Reports Access	Saleshub: - Reports: Full Ac	CUSTOM	8 permissions	⋮
Sales Admin	Saleshub: - Leads: Full Acce	CUSTOM	50 permissions	⋮

Role-Based Access Control (RBAC) Permissions Dashboard



× Update User
 Cancel Update

Full Name

Email

Role

Admin

Status

Active

Reporting Manager

Select Reporting Mana...

Auto assignable

Disabled

Resources

Product name	Action
SalesHub	☒
AccountCare	☒
AnswerPro	☐
DexyAI	☐
OneView	☒

Product Modules

SalesHub

Reports × Meetings × Calls × Leads × Deals × Contacts × Accounts ×

OneView

Customers × Project Management × Engagements × Tickets × OutReach ×
 Calendar × Price Approval × live-convo × Insights360 × Convo ×
 Dashboard × Email Templates × Customer Contacts / POCs × Tasks ×
 Opportunity × collections × Health × Contacts × CXO Dashboard ×

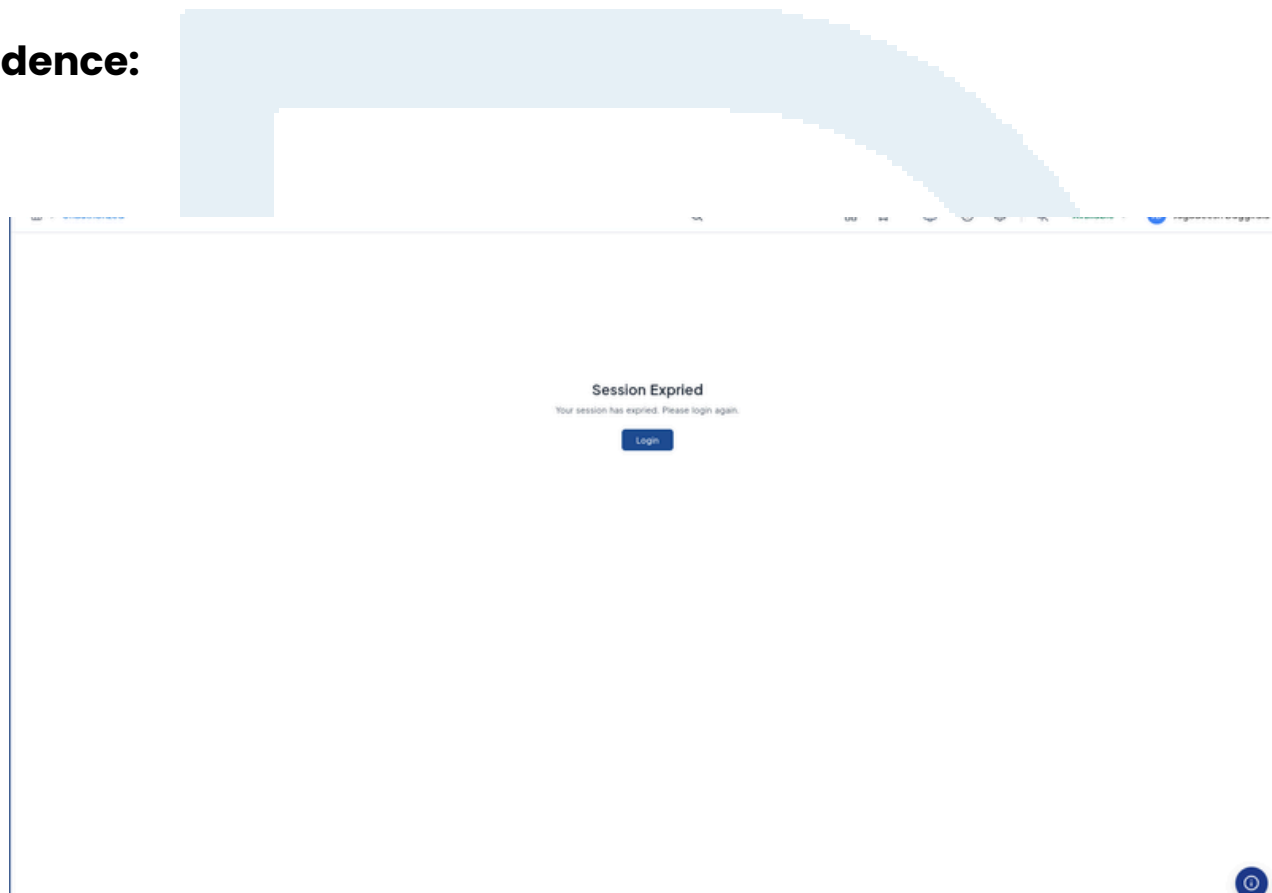
User Role and Permission Assignment Interface

5.3 Token-Based Security Model

Controls:

- Short-lived access tokens duration setup based on the client requirements
- Reduces risk of token compromise

Evidence:



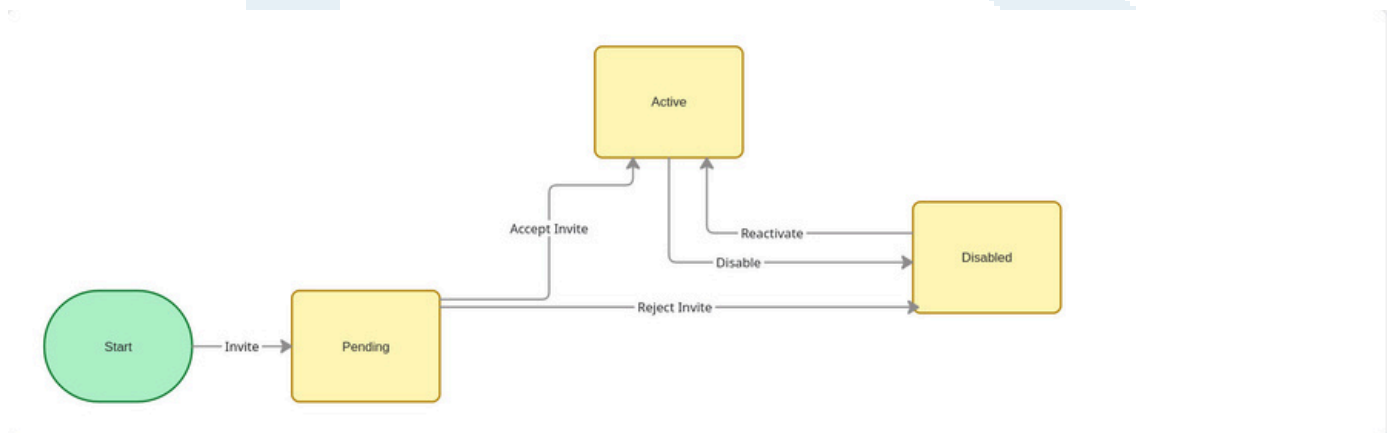
Token Generation and Validation Mechanism

5.4 Account Lifecycle Management

Controls:

- User states: Pending, Active, Disabled
- Enables manual verification and rapid access revocation
- User added via invitation by the admin user

Evidence:



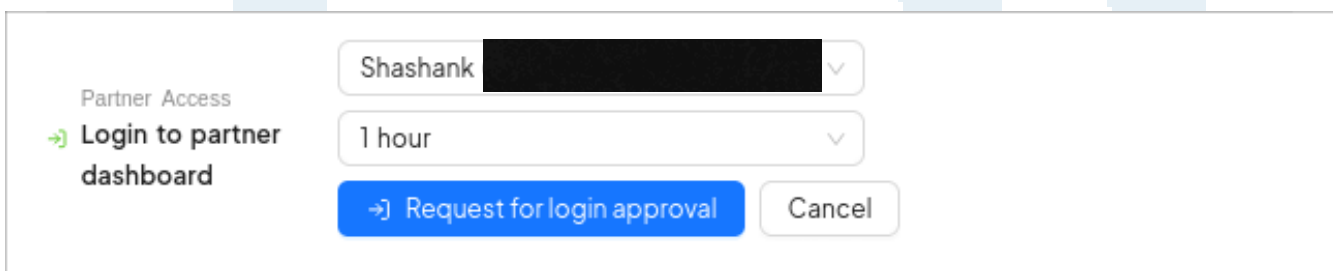
User Lifecycle State Management (Pending, Active, Disabled)

5.5 Internal Access Governance

Controls:

- Production access restricted to authorized engineers only
- Access granted by the approval of the admin user.
- Access granted for a limited time frame
- Access via IAM roles (no shared credentials)
- Access is logged and monitored
- Periodic access review (quarterly)
- Immediate revocation on role change / exit

Evidence:



Partner Access

→ Login to partner dashboard

Shashank [redacted] ▼

1 hour ▼

→ Request for login approval Cancel

6. Logging & Monitoring

6.1 Structured Logging

Controls:

- Winston-based structured logs
- Includes timestamps, user IDs, and request context

```
[AutoAssign] Skipping partner [redacted], auto-assignment disabled
[AutoAssign] Skipping partner [redacted] auto-assignment disabled
[Cron] Auto-assign job completed ✓
2026-04-21 14:28:00 | warn | 0 tickets has assigned a HelpDesk module.
2026-04-21 14:28:00 | info | Phone auto-close completed. Total tickets closed: 0 across 3 partners
🔥 CRON TRIGGERED: 2026-04-21T08:58:00.970Z
2026-04-21 14:28:00 | info | 🔄 Running property change cron job
❌ DISCONNECT | ID: 5OGgbsx52tdzdrjADfV | Source: widget | Duration: 158327ms | Reason: transport close
📶 SOCKET STATS | Active total: 126 | Widgets: 70 | Apps: 56
👤 PARTNER JOIN | Partner: [redacted] joined room.
-----
📶 SOCKET STATS | Active total: 127 | Total ever: 4587
🔄 BY SOURCE ACTIVE | Widgets: 71 | Apps: 56
✅ NEW CONNECT | ID [redacted] | Partner: [redacted] | User: N/A | Via: widget
```

Structured Application Logs

6.2 Security Event Logging

Controls:

- Dedicated log channels: error, warn, success
- Tracks failed login attempts and unauthorized access

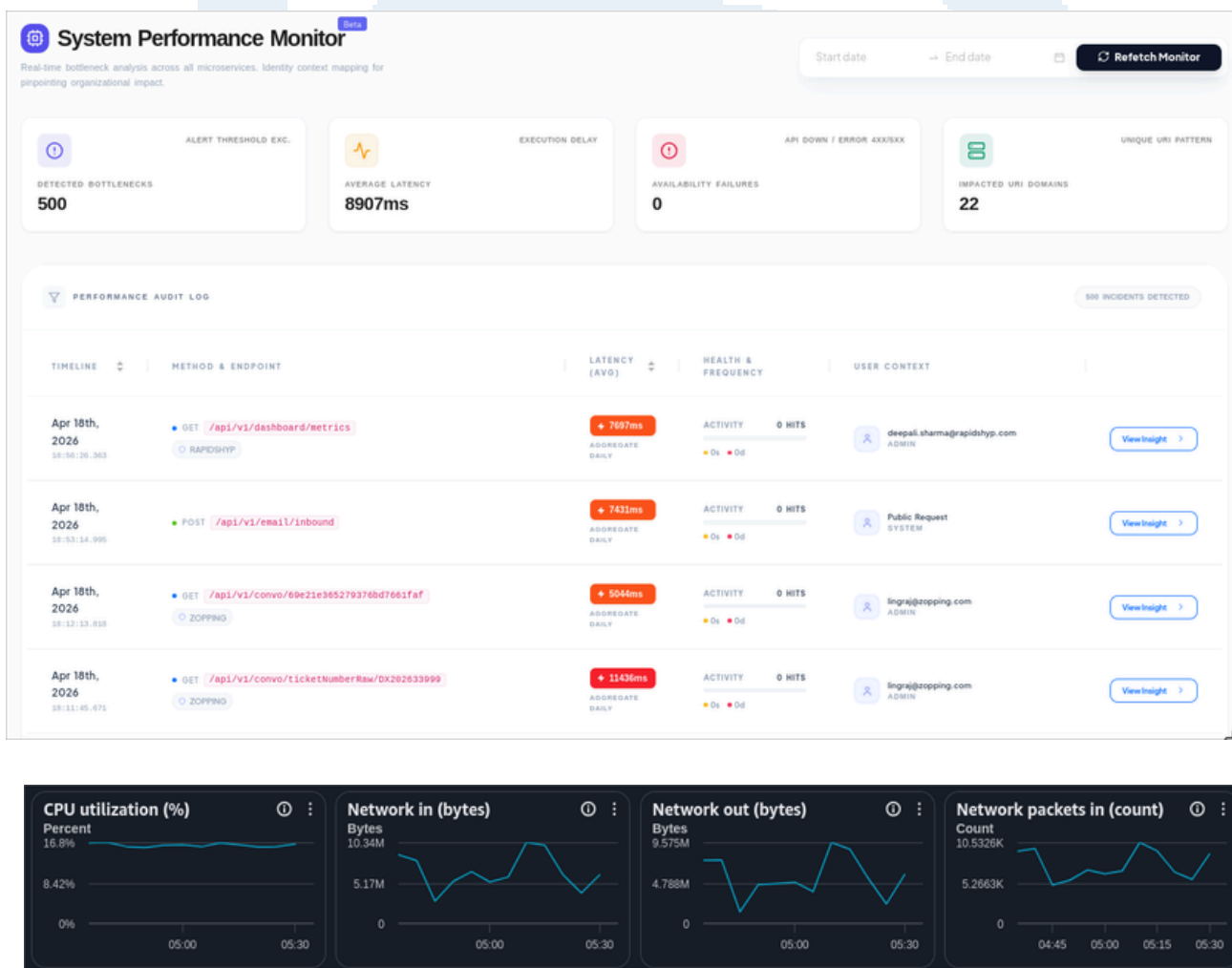


6.3 Performance Monitoring

Controls:

- Active System Monitoring using in-house monitoring dashboard
- API latency monitoring
- Detection of abnormal response times

Evidence:



System Performance Monitoring Dashboard (CPU, Network, API Metrics)



7. Backup & Disaster Recovery

Controls:

- Automated backups via managed services
- Restore capability maintained
- Backup restoration is periodically tested to ensure recovery integrity

Evidence:

Backup Policy

Snapshot Time (UTC)

01 hr 50 min

* Your selected time zone: 07:20 (GMT+5:30)

**This snapshot time applies to all rows in the table below.

Backup Policy Frequency and Retention

Frequency Unit ⓘ	Every	Retention Time ⓘ	Snapshot Time	
Hourly Snapshot	12 hours	3 days	01:50 UTC	DELETE
Daily Snapshot	N/A	3 days	01:50 UTC	DELETE
Weekly Snapshot	Saturday	4 weeks	01:50 UTC	DELETE
Monthly Snapshot	Last day of month	3 months	01:50 UTC	DELETE
Yearly Snapshot	First of April	1 years	01:50 UTC	DELETE

+ Add Frequency Unit

*Once a frequency unit has been created, it cannot be changed later. Snapshot interval and retention time can be further edited. More information on [Backup Policy docs](#).

Backup Policy and Retention Configuration

7.1 Business Continuity

- Defined recovery procedures
- Target RTO: 6 hours
- Target RPO: 30 minutes



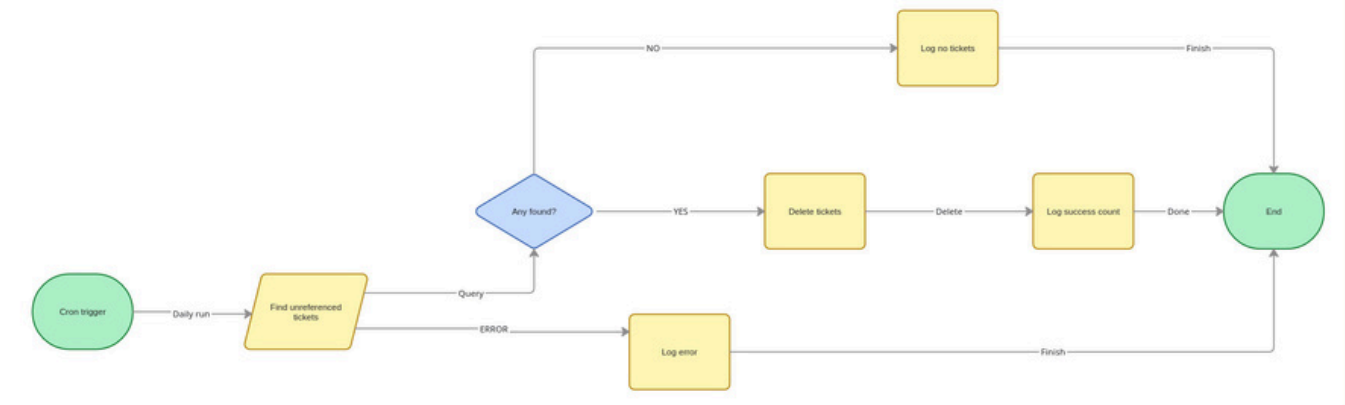
8. Data Retention & Deletion

8.1 Automated Cleanup

Controls:

- Cron-based deletion of unreferenced data runs every 5 mins.

Evidence:



Automated Data Cleanup via Scheduled Cron Jobs

8.2 User Data Deletion

Controls:

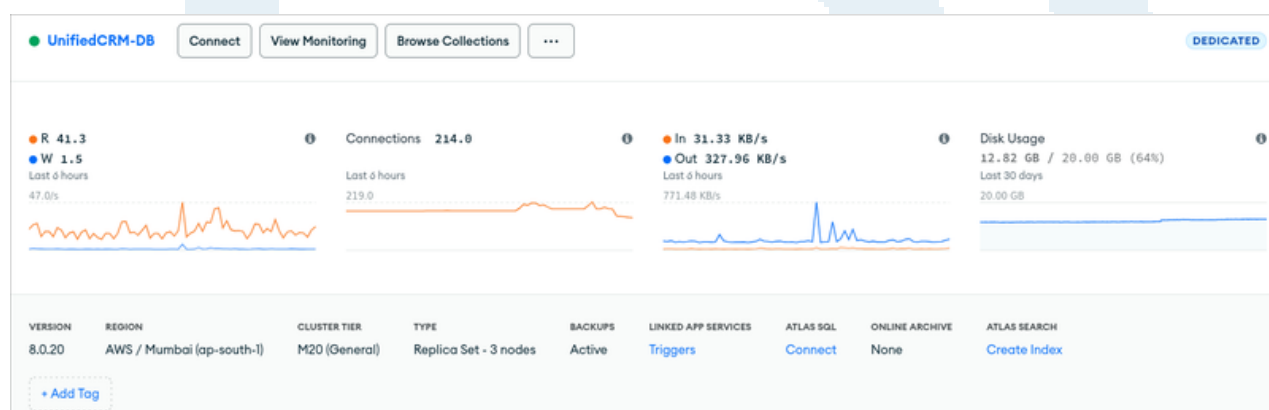
- API-based archival workflows
- Data is retained for 6 months after termination of the contract or can be configured based on customer agreement/contract.
- Supports "Right to be Forgotten"

9. Data Localization

Controls:

- Region-specific data storage
- Controlled cross-region data movement
- No sensitive customer data is transferred outside India by default. Any exceptions, if required, are strictly controlled and governed by security and compliance policies.

Evidence:



VERSION	REGION	CLUSTER TIER	ENCRYPTED STORAGE
8.0.20	AWS Mumbai (ap-south-1)	M20 (General)	True

MongoDB Deployment Region and Encryption Status (AWS Mumbai)



10. Application Security

10.1 Input Validation

Controls:

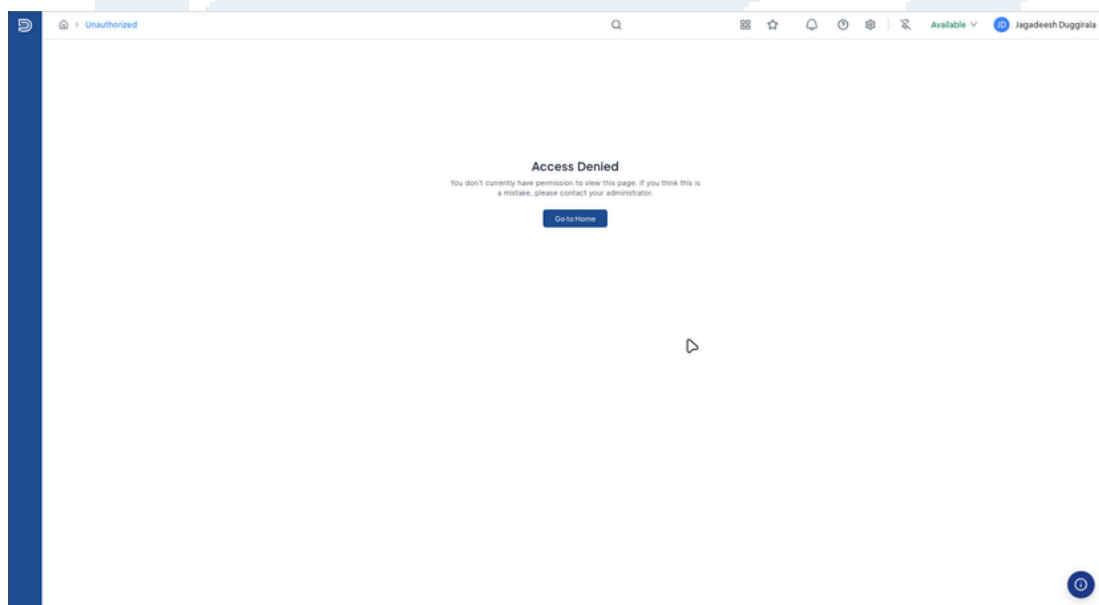
- Input sanitization via express-validator
- Protection against injection attacks using parameterized queries

10.2 Anti-DoS & Security Caching

Controls:

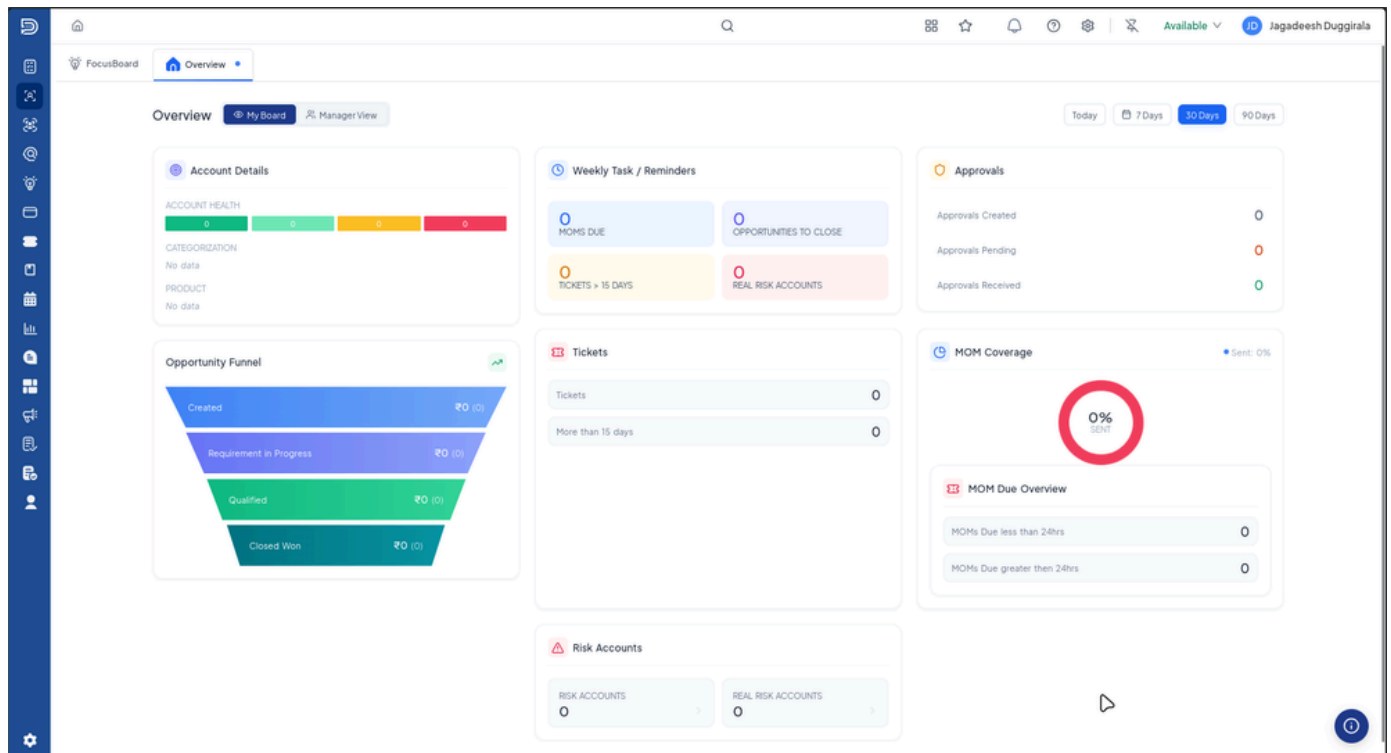
- TTL-based caching for JWTs and user profiles
- Caching recurrent queries on cache database
- Reduces repeated database hits
- Rate limiting on API and Authentication Calls

Evidence:

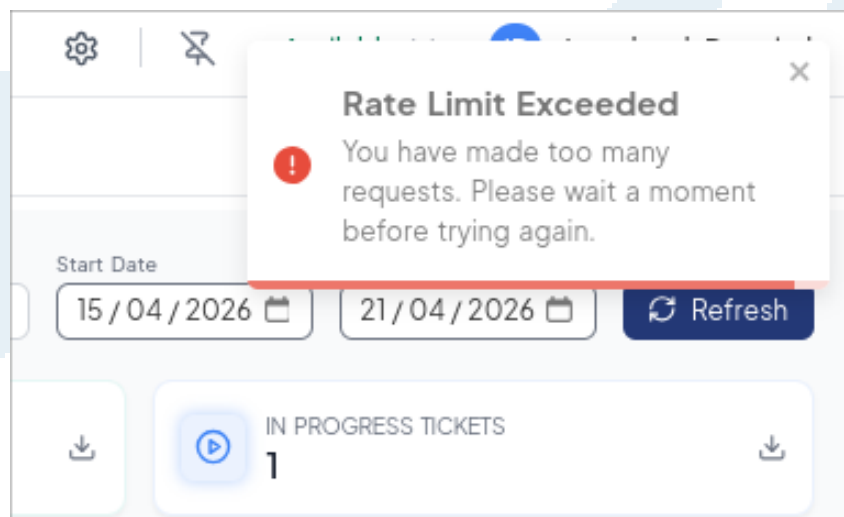


Token Validation Failure





Token Validation Success



API Rate Limiting Implementation

10.3 Resilience & Circuit Breaking

Controls:

- Retry logic with exponential backoff
- Prevents cascading failures

10.4 Secure API Architecture

Controls:

- Centralized error handling
- Standardized response structure

10.5 Vulnerability Management

Controls:

- Dependency scanning via npm audit
- Static analysis reports maintained



11. Internal Security Practices

Controls:

- Secrets stored in environment variables / secure vault
- No secrets in code repositories
- Access restricted via IAM roles
- Periodic rotation policy
- No hardcoded secrets
- Environment-based credential management
- Secure third-party integrations

Search keys...		
AWS_BUCKET_NAME	•	Run Time
AWS_BUCKET_NAME_ANSWERPRO	•	Run Time
SLACK_BOT_TOKEN	•_	Run Time
SLACK_APP_TOKEN	•_	Run Time
GOOGLE_CLIENT_ID	•_	Run Time
GOOGLE_CLIENT_SECRET	•	Run Time
GOOGLE_REDIRECT_URI	•	Run Time
GROK_API_KEY	•_	Run Time
NODE_OPTIONS	•	Run Time
MONGODB_EMAIL_EVENTS	•_	Run Time

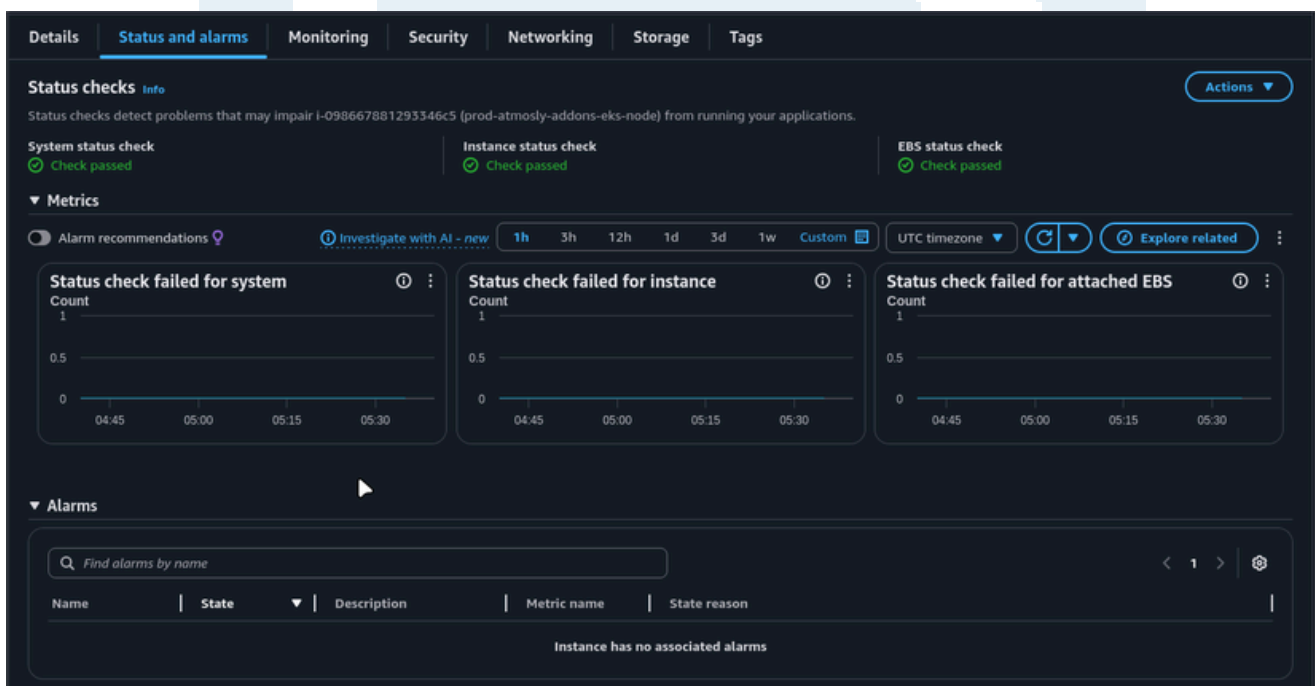
Environment-based credential management



12. Incident Management

Controls:

- Centralized logging for incident detection
- Root cause analysis and remediation
- Critical alerts are monitored and responded to in near real-time with defined escalation procedures.



System Health and Incident Monitoring Dashboard (AWS)

[← Back to Project Overview](#)

Project Alerts

Open Alerts **Closed Alerts** Alert Settings

Alert Description	Resolved
Query Targeting: Scanned Objects / Returned has gone above 1000 [REDACTED]	04/21/26, 05:56 PM ⓘ
System: Memory usage % has gone above 76 [REDACTED]	04/21/26, 04:54 AM
Query Targeting: Scanned Objects / Returned has gone above 1000 [REDACTED]	04/20/26, 08:02 PM ⓘ
System: Memory usage % has gone above 76 [REDACTED]	04/20/26, 05:47 PM ⓘ
System: Memory usage % has gone above 76 [REDACTED]	04/20/26, 02:48 PM ⓘ
System: Memory usage % has gone above 76 [REDACTED]	04/20/26, 02:11 PM ⓘ
System: Memory usage % has gone above 76 [REDACTED]	04/20/26, 01:26 PM ⓘ

Database Monitoring Dashboard (MongoDB Atlas)

TOTAL SESSIONS
996

JS & API ERRORS
12942

SLOW API DETECTED
7729

USER FEEDBACK
2

Top Problems

Auto-detected UX friction & Failures

API failure on active/ticket 77 IMPACT 3% TREND + FREQ 270+ API ERROR 3m	JavaScript Error on /cx-suite/convo-v2 77 IMPACT 1% TREND + FREQ 464+ JS ERROR 34m	JavaScript Error on /cx-suite/tickets 77 IMPACT 7% TREND → FREQ 1320+ JS ERROR 7m	API failure on ticketNumberRaw/undefined 71 IMPACT 7% TREND → FREQ 910+ API ERROR 366m
API failure on v2/search?page=1&limit=25 46 IMPACT 6% TREND + FREQ 977+ API ERROR 3m	JavaScript Error on /login 43 IMPACT 5% TREND + FREQ 150+ JS ERROR 84m	API failure on 687e31f7ab5d109a7275d987/get-all-integration 42 IMPACT 4% TREND → FREQ 224+ API ERROR 434m	Users confused by "element" 42 IMPACT 4% TREND → FREQ 124+ PAGE CLICK 20m

[Performance Issues \(20\)](#)
[API Failures \(20\)](#)
[Runtime & Console Errors \(24\)](#)
[User Complaints](#)
[Hub Integration](#)

API Endpoint	Method	Avg Latency	Count	Last Seen
https://auth-prod.dexkor.com/api/v1/users/availability-status/68a6d31415d9913752feed1	PATCH	1053.00s average	6 requests	21/4/2026, 5:31:54 am
https://api-prod.dexkor.com/api/v1/convo/69e21b675279376bd765b5fde	GET	993.34s average	1 requests	17/4/2026, 5:54:30 pm
https://api-prod.dexkor.com/api/v1/convo/ticketNumberRaw/30262634391	GET	993.34s average	1 requests	17/4/2026, 5:54:30 pm
https://api-prod.dexkor.com/api/v1/convo/69e21b675279376bd765b5fde/snooze	GET	993.33s average	1 requests	17/4/2026, 5:54:30 pm
https://api-prod.dexkor.com/api/v1/convo/spl1t/69e21b675279376bd765b5fde	GET	993.33s average	1 requests	17/4/2026, 5:54:30 pm

Application Monitoring Dashboard (DexKor)



+91 9354741240



contactus@dexkor.com



Innov8 Coworking Space, Orchid Center, 3rd Floor,
Sector 53, Gurugram, Haryana 122022

12.1 Incident Response SLAs

DexKor follows a structured incident response framework to ensure timely detection, containment, and resolution of security and operational incidents.

Incident Severity Classification

Severity Level	Description
Critical	Data breach, unauthorized access to customer data, or complete system outage
High	Partial service disruption, suspected security vulnerability, or degraded performance impacting multiple users
Medium	Isolated incidents with limited impact on specific users or features
Low	Minor issues with negligible business impact

Incident Handling Process

- Continuous monitoring systems detect anomalies and trigger alerts
- Incidents are logged and categorized based on severity
- Engineering and security teams are notified immediately for high-severity incidents
- Root Cause Analysis (RCA) is conducted for all critical and high-severity incidents
- Corrective and preventive actions are implemented to avoid recurrence



Response Time Objectives

Severity Level	Initial Response Time	Resolution / Mitigation Target
Critical	Within 15 Min	Immediate containment and continuous resolution efforts
High	Within 2 hours	Resolution within 24 hours (or workaround provided)
Medium	Within 4 hours	Resolution within 2–3 business days
Low	Within 8 hours	Addressed in planned release cycles

Escalation

- Critical incidents are escalated to senior engineering and leadership teams
- Dedicated resources are assigned until resolution
- Communication is maintained internally at defined intervals



12.2 Customer Notification

DexKor is committed to transparency and timely communication in the event of security incidents that may impact customer data or service availability.

Notification Triggers

Customers will be notified in the event of:

- Confirmed or suspected data breaches
- Unauthorized access to customer data
- Security incidents with potential impact on data confidentiality, integrity, or availability
- Major service disruptions affecting customer operations

Notification Timeline

- Initial Notification: Within 24–72 hours of confirming the incident
- Ongoing Updates: Provided as investigation progresses
- Final Report: Shared after resolution, including root cause and remediation actions

Notification Details

Customer communication will include:

- Nature and scope of the incident
- Type of data potentially affected (if applicable)
- Timeline of the incident
- Immediate actions taken by DexKor
- Recommended actions for customers (if required)
- Steps taken to prevent recurrence



Communication Channels

- Email communication to registered customer contacts
- Account-level notifications (if applicable)
- Direct communication for critical enterprise customers

Regulatory Alignment

DexKor aligns its incident communication practices with applicable data protection and regulatory expectations, including timely disclosure and responsible handling of customer data incidents.

13. Compliance Positioning

DexKor currently operates with security controls aligned to SOC 2 and ISO 27001 best practices. Formal certification is part of our planned roadmap.

However, controls align with:

- OWASP Top 10
- Cloud-native security best practices

14. Data Classification

- Customer Data (PII)
- Communication Data (messages)
- Metadata (logs, timestamps)

15. Declaration

DexKor is committed to continuously improving its security posture and aligning with industry standards.



16. Frequently Asked Questions (FAQ)

Q1. Is customer data encrypted?

Customer data is encrypted at rest using AES-256 and in transit using TLS 1.2+ over HTTPS.

Q2. Where is customer data stored?

Customer data is hosted in AWS (ap-south-1 – Mumbai region) using region-restricted infrastructure.

Q3. How are encryption keys managed?

Encryption keys are managed using cloud provider-managed key management systems (e.g., MongoDB Atlas managed keys / cloud-native KMS).

Q4. Where is the infrastructure hosted?

Infrastructure is hosted on Amazon Web Services (AWS) in the Asia Pacific (Mumbai) region.

Q5. Is customer data restricted to a specific region?

Customer data is stored within the India region and cross-region transfer is controlled and not performed without authorization.

Q6. Is network isolation implemented?

Yes. Network isolation is implemented using AWS Virtual Private Cloud (VPC) with restricted access configurations.



Q7. How is user authentication handled?

Authentication is managed through a centralized Auth Microservice using token-based authentication.

Q8. Is role-based access control (RBAC) implemented?

Yes. Fine-grained RBAC is implemented with role, team, and tenant-based permissions, enforcing least privilege.

Q9. How is unauthorized access prevented?

Unauthorized access is mitigated through OTP-based authentication, token validation, rate limiting, and continuous monitoring.

Q10. How is tenant data isolation ensured?

Tenant data isolation is enforced using unique tenant identifiers, ensuring all queries are scoped to tenant context.

Q11. Are audit logs maintained?

Yes. Structured logs are maintained for user activity, system events, and API interactions.

Q12. Are security events monitored?

Yes. Security events such as failed login attempts, unauthorized access, and anomalies are logged and monitored.

Q13. Are data backups performed?

Yes. Automated backups are performed using managed cloud services.



Q14. Are backups tested for recovery?

Yes. Backup restoration is periodically tested to ensure recovery integrity.

Q15. What is the data retention policy?

Data is retained for 6 months after termination of the contract unless otherwise agreed.

Q16. Are data deletion requests supported?

Yes. API-based data deletion workflows are supported, including "Right to be Forgotten" requests.

Q17. How are common security vulnerabilities mitigated?

Controls include input validation, parameterized queries, secure authentication flows, and rate limiting.

Q18. Is vulnerability scanning performed?

Yes. Dependency scanning and security checks are performed regularly.

Q19. How are security incidents handled?

Security incidents are monitored, analyzed, and resolved through structured incident management processes.

Q20. Are alerts generated for critical issues?

Yes. Critical alerts are monitored and responded to in near real-time with defined escalation procedures.

Q21. How are security incidents communicated to customers?

Refer 12.2 section

